

TRY NEX LIFESTYLE

FULL-STACK AUDIT AND RELEASE OVERVIEW

Evidence date: 02 September 2026 (Asia/Dhaka)

Executive status

RUNTIME AND COMMERCE: PASSING THE VERIFIED LOCAL AND PROXIED GATES

MOCKUP RELEASE: 188/188 SMART-V9 CANDIDATE ASSETS VALIDATED

NATIVE PHOTOSHOP SMART OBJECTS: NOT COMPLETE; RUNTIME MARKED MANIFEST-ONLY

OPERATIONS: RUNNING WITH DATABASE, R2, AND PRIMARY RUNTIME HEALTHY

KNOWN DEGRADED SERVICE: CONFIGURED UPSTASH REDIS BACKENDS UNAVAILABLE

This document records what was inspected, what is live, what was changed, what was verified, and what must not yet be claimed. It deliberately separates a validated browser/runtime PNG matrix from native Photoshop Smart Object masters.

Prepared from the current repository, running workflow, source-kit audits, automated tests, production builds, and proxied endpoint smoke checks.

1. SCOPE AND RELEASE VERDICT

The audit covered the complete TryNex Lifestyle workspace rather than relying on an earlier agent report:

- Customer storefront and product catalog
- Browser Design Studio, 2D editing, 3D preview, composition, and cart flow
- Six product families: T-shirt, Long Sleeve, Hoodie, Mug, Cap, Water Bottle
- Product colors, faces, print zones, normalized frames, and runtime paths
- API routes, database access, failover behavior, storage, cache, and health
- Admin sessions, TOTP, authorization, AI assistant, and management routes
- Uploads, checkout, payment metadata, mobile app behavior, and SEO
- Cloudflare Pages proxy, API service, workflow, and deployment configuration
- PSD/PSB source documents and genuine Smart Object structure
- Dependency, SAST, path-safety, and privacy/security evidence

Release verdict

The current storefront/API release is operational and passes its automated and proxied smoke gates. The 188-surface smart-v9 candidate is technically valid (1024x1024 RGBA PNGs, accepted rows, matching hashes). Runtime exceptions are explicit and source-specific: reviewed PSD-derived T-shirt front/back PNGs, authentic Water Bottle v1.1 front/back, and reviewed color-specific source matrix assets for Long Sleeve/Hoodie Charcoal, Royal Blue, and Sand.

The editable source kit is not a native Smart Object release. All 108 audited PSD/PSB files open, but all 108 contain zero genuine Smart Object layers. The runtime manifest now says manifest-only; no false verified claim is shipped.

2. ARCHITECTURE AND REQUEST FLOW

Browser / customer or admin

|
v

Vite storefront (local :8080; static Pages production artifact)

| /api/* through the artifact path and Pages gateway function

v

Express API server (local :8082; Render/API production service)

|-- Drizzle ORM -> Neon PostgreSQL candidate chain

|-- Object storage -> R2 in the current runtime; local fallback exists

|-- Upstash Redis -> optional cache/rate-limit backend (degraded now)

|-- Admin/AI, Telegram, checkout, products, orders, reviews, settings

v

Database, storage, notifications, and controlled external service boundaries

The configured workflow builds the API, starts it on port 8082, and starts the storefront on port 8080. The API is a compiled esbuild bundle, so API source changes require a build and workflow restart; this was done for this audit.

The public deployment model reviewed in the repository is Cloudflare Pages for the static frontend, with a Pages function proxying /api/* to the API service. The storefront also proxies sitemap.xml to the API in development so the same route is testable through the local preview path.

3. PRODUCT, API, DATABASE, AND STORAGE FLOW

Catalog flow

1. Storefront requests products/categories/settings from the API.
2. Products route reads the Drizzle/Neon catalog with filtering and pagination.
3. Cached public responses are used where configured; no product data is silently fabricated when the API is unavailable.
4. Product and Design Studio metadata carry category, color, face, print-zone, original artwork, and studio design information into cart and order payloads.

Order and asset flow

Customer input -> validated POST /api/orders -> order/item records in PostgreSQL
-> original/design assets referenced by controlled object keys -> admin order review, payment status, notifications, and fulfillment workflow.

Storage controls verified in this pass

- Upload request validates filename, size, MIME type, and a 25 MB ceiling.
- Direct binary upload verifies magic bytes and declared content type.
- JPEG, PNG, GIF, WebP, PSD, and PSB types are explicitly handled.
- Private object paths accept direct upload IDs or the known four-part order key.
- Traversal and encoded traversal are rejected with a not-found response.
- Unsafe input is rejected, not sanitized into a different valid filename.
- Public runtime folders contain no PSD/PSB masters.

4. SIX-FAMILY MOCKUP CONTRACT

The release matrix is 188 surfaces:

T-shirt	8 colors x 5 views = 40
Long Sleeve	10 colors x 5 views = 50
Hoodie	10 colors x 5 views = 50
Mug	10 colors x 3 views = 30
Cap	8 colors x 2 views = 16
Water Bottle	1 color x 2 views = 2

	188

Every candidate surface has a canonical source key, runtime URL, SHA-256 hash, accepted status, provenance, 1024x1024 RGBA PNG dimensions, and a corresponding print-zone/geometry entry. The standalone validator checks the actual public file, the manifest row, the hash, dimensions, color type, and stale roots.

Runtime resolution is intentionally not a blind one-to-one claim:

- T-shirt front/back: /mockups/psd-tshirt-v1 color-specific reviewed PNGs.
- T-shirt remaining faces: accepted smart-v9 matrix.
- Long Sleeve/Hoodie: smart-v9 where the exact catalog color exists; Charcoal, Royal Blue, and Sand stay on their reviewed source-matrix color assets.
- Mug and Cap: smart-v9 covers every catalog face.
- Water Bottle: hash-pinned /mockups/waterbottle-v11 white front/back only.

This avoids silently mapping a catalog shade to a different hue. Water Bottle does not expose synthetic colored-body variants because the supplied product is a white sublimation-coated aluminum blank without distinct physical masters.

5. PRINT ZONES, FACES, AND RENDERING

Apparel exposes Front, Back, Left Sleeve, Right Sleeve, and Neck Label. Mug exposes front, back, and wrap geometry. Cap exposes front and back. Water Bottle exposes front and back with bottle-body clipping.

Print zones are contract data, not guesses from gallery image bounds. They carry shape-aware paths for mug body, cap front, and bottle body. Normalized frames keep product scale stable when switching face or color. Curved products use the 3D preview by default; flat apparel defaults to 2D precision editing.

Preserved Design Studio behavior includes:

- Product switching re-fits the artwork to the destination print zone.
- Undo/redo and product-aware history remain in place.
- Uploaded original artwork and studio metadata survive cart and checkout.
- Immediate/local uploads remain available instead of requiring a remote upload to preview the design.
- Curved-product composition and final rendering remain separate from precise 2D placement, preventing a 2D editor approximation from being called 3D.
- White, dark, and color-specific garment blending rules remain explicit.

6. PSD/PSB AND SMART OBJECT TRUTH

Source-kit audit result

108/108 PSD/PSB documents opened successfully.

All are 1024x1024, 8-bit RGB/RGBA-compatible documents with composite data.

Each has six named layers and an artwork placeholder layer.

0/108 contains a genuine Photoshop Smart Object layer.

Therefore these documents are honest raster/source masters with named layers, not completed native Smart Object masters. A layer named "Artwork - Place Design Here" is not itself proof of Smart Object structure.

A separate quarantine writer can produce representative embedded-Smart-Object proof files, and that writer has been structurally audited for representatives. However, no production promotion is claimed because the complete 188-surface native master set still needs provenance, structural reopen checks, contact-sheet review, browser/PSD comparison, and controlled acceptance.

The runtime manifest correction in this pass is important: resolveMockup now sets masterStatus to manifest-only for current surfaces. It will not claim verified until the exact master has been reopened and passed the native Smart Object gate. Source masters remain outside public runtime directories.

7. ADMIN, AUTHENTICATION, AND AI

Admin routes reviewed include login, TOTP setup/enable/disable, password change

and reset, sessions, logout, catalog management, customers, orders, reviews, testimonials, Telegram, Facebook import, storage optimization, health, backup, settings, mockups, and deployment-related controls.

Admin authentication is session-based with a database-backed admin/session model and TOTP support. CSRF, origin, security headers, and rate-limit middleware are part of the API boundary. The emergency development bypass is environment-gated and must not activate in unknown or production environments.

The AI developer route supports natural-language admin preview/execute behavior with allowlisted product/order/admin actions and database-configurable system prompt settings. The final report does not claim autonomous deployment or unsafe self-modifying production behavior.

Limitation: the protected GET `/api/admin/system/health` endpoint was not tested with an authenticated admin session in this pass. The unauthenticated response was an error shape, so no protected-admin-health success claim is made.

8. CHECKOUT, MOBILE, SEO, AND CUSTOMER FLOWS

Checkout

The checkout contract retains settings-driven shipping, payment contact numbers, free-shipping threshold, order validation, and the 25 percent advance/COD deposit rule documented across customer and admin paths. Sender/payment evidence and order metadata are carried into the API order flow. A real payment transaction was not created during this audit, so provider settlement is outside the evidence.

Mobile

The Expo mobile artifact uses the same API contract, reads checkout settings dynamically, preserves studioDesign/originalAssets metadata, and uses inline field validation for name, phone, and address rather than interruptive alerts. Mobile Render domain fallback behavior is present for the known stale API domain case.

SEO and discovery

The storefront contains route-aware SEO components, JSON-LD, product review guard rails, a dynamic sitemap, robots rules, and public route metadata. The live smoke checks returned 200 for sitemap.xml and robots.txt. The SPA limitation remains: non-JavaScript social crawlers may see generic index metadata rather than route-specific client-rendered SEO content.

9. DEPLOYMENT AND LIVE WORKFLOW EVIDENCE

Configured application workflow restarted successfully after the final API and storefront changes. Logs showed:

- Vite storefront listening on 0.0.0.0:8080.
- API server listening on port 8082.
- R2 selected as the active storage backend.
- Database connected to a healthy candidate with current order/product counts.
- Migrations completed without applying pending migrations.
- Scheduler active.

Proxied runtime checks returned:

```
/api/healthz      200 (degraded only because Redis is unavailable)
/api/health/liveness 200
/api/health/readiness 200
/api/products     200
/api/categories   200
/api/settings     200
/sitemap.xml      200
/robots.txt       200
Representative mockup PNGs 200
```

The artifact screenshot registry could not resolve this checkout, so no new browser screenshot is presented as evidence. Existing repository screenshots are historical visual evidence and are not substituted for a fresh browser capture.

10. FIXES APPLIED IN THIS PASS

1. Object-storage path hardening

Added rejection for traversal, encoded separators, invalid private prefixes, and unsupported arbitrary nested paths; preserved legitimate order keys and direct upload IDs. Added focused tests.

2. Upload validation hardening

Added size, MIME, magic-byte, and declared-type consistency checks, including PSD/PSB signature handling without routing masters through image optimization.

3. Runtime release contract correction

The standalone validator now validates the smart-v9 tree and candidate hashes instead of certifying the retired smart-v4 tree. The sitemap Vite proxy was added for the root development route.

4. Smart Object status honesty

Runtime manifests now say manifest-only because the audited source kit has no genuine Smart Object layers. A regression test guards this claim.

5. Compatible dependency updates

Transitive browserslist was refreshed to 4.28.8 and decode-uri-component to 0.5.0 through workspace overrides and lockfile regeneration.

Working commerce, Design Studio, upload metadata, curved-product rendering, settings-driven checkout, authentication, failover, and admin behavior were not replaced or reset.

11. SECURITY FINDINGS AND RISK REGISTER

Resolved or reduced

- Storage traversal and arbitrary private-path risk: hardened and covered by tests.
- Upload content mismatch risk: magic-byte/type checks added.
- Outdated browserslist and decode-uri-component: compatible updates applied.

Accepted with explicit limitation

- image-size: two high advisories remain through Expo/Metro build tooling. The current published image-size line is still affected and the advisory lists no patched version. This is not used as the customer image upload parser in the API path; it remains a dependency/toolchain risk requiring upstream or parent package remediation.
- TOTP SHA-1: SAST flags the HMAC algorithm, but SHA-1 is required for standard RFC-compatible TOTP authenticator interoperability in the current flow. A blind replacement would invalidate existing authenticator codes. Keep the finding documented and revisit with migration support if stronger algorithm policy is required.
- Redis: health is degraded because configured Upstash backends are unavailable; database, storage, primary runtime, and scheduler remain healthy.

No HoundDog findings were reported in the completed security scan. Security status does not imply authenticated admin or payment-provider end-to-end proof.

12. VERIFICATION RESULTS

Passed

pnpm validate:mockups	188 expected / 188 candidate assets
Storefront tests	22 files / 76 tests
API tests	6 files / 26 tests
Storefront typecheck	passed
API typecheck	passed
Full workspace typecheck	passed
Storefront production build	passed
API production build	passed
PSD/PSB structural audit	108 openable / 0 unreadable
PSD dimensions	1024x1024 for all 108
PSD layer structure	six layers per document
Genuine Smart Objects	0 in all 108 source-kit documents
git diff --check	passed
Managed workflow restart	passed
Proxied health/catalog/SEO smoke	passed
Invalid order body	400 validation_error
Invalid upload request	400 validation_error
Unsafe encoded object paths	404 not found
Public PSD/PSB exposure scan	0 files

The only non-passing command was the intentional non-zero exit from pnpm audit because two high image-size advisories remain. It produced no other advisory classes after the compatible dependency updates.

13. INCOMPLETE WORK AND NEXT SAFE ACTION

Incomplete by design

- The complete six-family native PSD/PSB Smart Object release is not promoted.
- The 188-surface candidate has not been proven as 188 native Smart Object masters.
- Fresh browser visual screenshot evidence is unavailable because the artifact registry cannot resolve this checkout.
- Protected admin system-health success and real payment settlement were not live verified in this pass.

Next safe action

Create a quarantine-only Smart Object workstream. Generate or ingest one exact master per family/color/face, reopen each with the structural auditor, compare rendered composites/contact sheets, validate print zones and protected details, then promote only after all 188 provenance and visual gates pass. Keep every unproven surface at manifest-only and keep editable masters out of public runtime.

Do not enable masterStatus: verified merely because a PNG looks correct or a layer has an artwork-shaped name.

APPENDIX: KEY FILES AND EVIDENCE

Runtime and contracts

artifacts/trynex-storefront/src/pages/design-studio/mockups.tsx
artifacts/trynex-storefront/src/pages/design-studio/complete-mockup-matrix.ts
artifacts/trynex-storefront/src/pages/design-studio/smart-v9-release.ts
artifacts/trynex-storefront/src/pages/design-studio/smart-v9-candidate.generated.ts
scripts/validate-mockup-matrix.mjs

Storage and API

artifacts/api-server/src/lib/objectStorage.ts
artifacts/api-server/src/lib/objectStorage.test.ts
artifacts/api-server/src/routes/storage.ts
artifacts/api-server/src/routes/orders.ts
lib/db/src/schema/index.ts

Source and audit tools

attached_assets/trynex-mockup-source-kit/psd
tools/audit_psd_masters.py
tools/build-smartobject-mockups.mjs
docs/superpowers/specs/2026-09-01-six-family-psd-smart-mockup-design.md

Operational handoff

AGENT_HANDOFF.md
artifacts/trynex-storefront/.replit-artifact/artifact.toml
artifacts/api-server/.replit-artifact/artifact.toml

Final statement

TryNex is operational for the verified storefront/API and raster mockup runtime.
It is not accurate to call the current 108 editable PSD/PSB source files native
Smart Object masters. The code and handoff now preserve that distinction.